

Juan Pablo de Legarreta

NETC 280 – IT Documentation

Lab 4

February 10, 2026

## APPLYING NIST CSF 2.0 TO EQUIFAX BREACH CASE STUDY

### 1. IDENTIFY THE WEAKEST FUNCTION

Of the six different functions of CSF 2.0 (Govern, Identify, Protect, Detect, Respond, and Recover), the one that failed the most and allowed the Equifax breach of 2017 to happen is **Protect**. The Protect function “supports the ability to secure those assets to prevent or lower the likelihood and impact of adverse cybersecurity events, as well as to increase the likelihood and impact of taking advantage of opportunities.” (NIST) In the Equifax breach, several protective measures failed, making it the weakest function. The investigation’s findings revealed that:

1. Systems were not properly segmented from each other (Fruhlinger)
2. Critical usernames and passwords were stored in plain text (Fruhlinger)
3. Encryption certificates that could have prevented the exfiltration of data were not renewed. (Fruhlinger)

### 2. GOVERNANCE ANALYSIS

In the Equifax breach, several critical failures led to the breach of personal information of 147 million U.S. customers, “primarily names, Social Security numbers, birth dates, addresses and, in some instances, driver’s license numbers.” (Equifax) Several news outlets confirmed that Equifax had policies and security practices that were much too lax. (Newman) Because of these lax policies and practices, many security risks were not properly prioritized. This is a systemic failure, where the blame rests in company policy and culture, falling under the umbrella of governance.

Company leadership at the highest level, as well as in the branch of IT should be held accountable for the breach. No sense of urgency in patching; a lack of security best practices in network segmentation, encryption, network monitoring, and not storing passwords in plain text; failure of security systems to detect and contain vulnerabilities and flaws; and lacking any kind of auditing or testing policy to verify their systems’ efficacy are all failures of security oversight by company leadership.

If leadership had handled cybersecurity better, it could have prevented the breach in the first place or at least limited the damage of the breach. With better patching the attackers may not have accessed the system in the first place. With network segmentation, Equifax could have kept the attackers contained and avoided lateral movement within their network. With no passwords stored in plain text, the attackers may have had no ability to access further systems. With stronger monitoring tools, Equifax would have detected the data exfiltration much sooner and could have put an end to it quickly. All of these security controls could have been better implemented with stronger policies, better oversight, and a commitment to good governance and risk management.

### 3. PREVENTATIVE CONTROLS

Several preventative controls could have existed to prevent or reduce the damage from the Equifax breach for each of the following components of the breach:

#### A. Patch not installed

Part of the **Protect** and **Govern** functions, patch management policy and execution could have easily prevented this breach. “The breach originated from a failure to patch a critical vulnerability known as Apache Struts CVE-2017-5638, which had been disclosed months before the attack.” (Danielson) The patch should not have taken *months* to be implemented. A stronger patch management protocol would have required the patch to have been installed much sooner. Having accountability and stronger oversight on patch management would have drastically reduced the time between the patch release and its installation.

#### B. Systems not being discovered during scan

Part of the **Protect** function, a thorough analysis and scan of systems for vulnerabilities is crucial to ensure that all systems are being adequately secured. If Equifax had used a better scanning tool, it may have discovered the vulnerabilities much more quickly and could have prevented the breach in a more timely manner. Reportedly, the scans it had used failed to identify the Apache Struts vulnerability among other conditions that led to the breach. (Danielson) Equifax should have had more frequent independent audits or have used a better tool to detect its vulnerabilities.

#### C. Credentials stored in plain text

Part of the **Protect** function, identifying and properly storing sensitive information would have eliminated the attackers’ ability to access additional systems after using the Apache Struts vulnerability. Equifax should have used

encryption on critical systems and files as well as implemented better practices to not store passwords and usernames in plain text. If encryption had been used to protect credentials and other systems, the attackers would not have been able to exploit other systems and applications within the network.

**D. Monitoring system not functioning**

Part of the **Detect** function, IDS/IPS and SIEM tools are critical to ensuring that accurate monitoring of networks and system traffic occurs. If Equifax had used better detection tools or a stronger SIEM, it would have been able to detect malicious activity much sooner than they did. In the Equifax breach, errant activity was first discovered at the end of July, several weeks after mid-May, when the initial Apache Struts breach occurred. (Equifax) This is unacceptable – the attackers “extracted troves of sensitive personal information without immediate detection” for several months! (Danielson)

**E. Data was stolen for months without detection**

Part of the **Detect** function, detection of exfiltration of data falls on a strong SIEM or network monitoring tool. With periodic network monitoring tests, network sniffing, and maintaining up-to-date encryption certificates, Equifax could have prevented or (at the very least) could have more quickly detected data exfiltration. These methods, coupled with a frequently updated and maintained SIEM tool, could have prevented the breach to have been as thorough as it was.

#### 4. BREACH TIMELINE THINKING

The breach occurred over a couple of months, building from one level of severity to the next over that time, culminating in weeks of sensitive data exfiltration. (Danielson) The breach started off simple, with the attackers taking advantage of a vulnerability in the Apache Struts web application. (Newman) From there, the attackers were able to move laterally through the network, found passwords in plain text to access even more systems, and pulled encrypted data out of the system without detection. (Fruhlinger) Each step that the attackers took made the breach grow worse over that time! The failure on Equifax’s part to patch the vulnerability, have better security practices, employ good network monitoring tools, and have updated security controls indicates a failure of multiple tools, systems, practices, policies, and governance by Equifax, culminating in the theft of *millions* of people’s PII.

#### 5. PREVENTION RECOMMENDATIONS

The single most important change that would have prevented this breach is a strong patch management policy. A strong patch management policy with outlined timelines

and expectations from the top would assist middle and lower management to ensure that patches get installed as soon as possible. This would come with job description clarification and role assignment to ensure that no tool, system, application, or network would go unpatched for too long again. This would specify ownership of the process and outline how to achieve it accurately for employees and security professionals, preventing it from slipping through the cracks again.

## 6. FINAL REFLECTION

This breach has clearly and, frankly, painfully displayed how systemic laziness in cybersecurity can result in catastrophic breaches and cybersecurity failure. Without proactive governance, policy, expectations, and oversight over protecting the networks, systems, and data under the stewardship or use of an organization, seemingly small or insignificant failures can snowball and result in huge cybersecurity breaches.

Organizations need strong security practices that are outlined and mandated in strong governance policy and enforced by proactive and strong leadership at every level. Lax security posture affects not just the company's bottom line, but potentially the very lives of the customers it presumes to serve or protect. Strong governance and implementation of security policy and practices is crucial for keeping data and people safe from bad actors.

## SOURCES

Danielson, Lizzie. "Equifax Data Breach." *Huntress.com*, 14 Nov 2025,  
<https://www.huntress.com/threat-library/data-breach/equifax-data-breach>

Equifax. "Equifax Releases Details on Cybersecurity Incident, Announces Personnel Changes." *Equifax Inc.*, 15 Sept 2017, <https://investor.equifax.com/news-events/press-releases/detail/237/equifax-releases-details-on-cybersecurity-incident>

Fruhlinger, Josh. "Equifax data breach FAQ: What happened, who was affected, what was the impact?" *CSO*, 12 Feb 2020,  
<https://www.csoonline.com/article/567833/equifax-data-breach-faq-what-happened-who-was-affected-what-was-the-impact.html>

Newman, Lily Hay. "Equifax Officially Has No Excuse." *Wired*, 14 Sept 2017,  
<https://www.wired.com/story/equifax-breach-no-excuse/>

NIST. "The NIST Cybersecurity Framework (CSF) 2.0." *The NIST Cybersecurity Framework (CSF) 2.0*, vol. 2.0, no. 29, 26 Feb. 2024,  
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>